EXPERIMENT 12

Implementing Security Features and Governance / Administration Practices in Zoho Creator

Vehicle Service& RepairRequest Management — Security and Governance Use Case

samyuktha.b
241401091

1. Aim

To plan and apply security features and governance and administration practices in the Vehicle Service & Repair Request Management application built in Zoho Creator — covering sign-in security, user access, data permissions, safe scripting and integrations, controlled changes and auditing — so that owner and vehicle data is protected and the application is managed in an orderly way.

The application stores personal and vehicle details such as owner name, email address, contact number, pickup address, vehicle registration number, odometer reading, issue description and the owner's authorization for the service center to proceed, so access control and accountability are essential.

2. Procedure

Step 1: Identify what needs protection — The Service_Request_Form and Service_Request_Report were reviewed, and the sensitive data was listed: owner identity, contact number, email address, pickup address, vehicle registration number, issue description and the estimate-and-repair authorization.

Step 2: Plan account security — Sign-in protection was planned for all users: strong passwords, two-factor sign-in and single sign-on where the organisation uses it (Section 3.1).

Step 3: Design roles and permissions — Four user types — Administrator, Front Office Executive, Technician and Vehicle Owner — were defined, and a permission matrix was prepared following the principle of least privilege (Section 3.2).Vehicle Owner — were defined, and a permission matrix was prepared following the principle of least privilege (Section

Step4:Define the access flow — The checks made when a user opens the application were drawn as a decision flow (Section 3.3).

Step 5: Secure scripts and connections — Safe Deluge practices were drafted, such as validating input and keeping connections limited to administrators, based on the earlier form validation and acknowledgement email work (Section 3.4).

Step 6: Set up governance — Controlled changes through development, stage and production environments, audit review and periodic access reviews were planned (Section 3.5). The Development to Stage deployment of this application was carried out in Experiment 11.

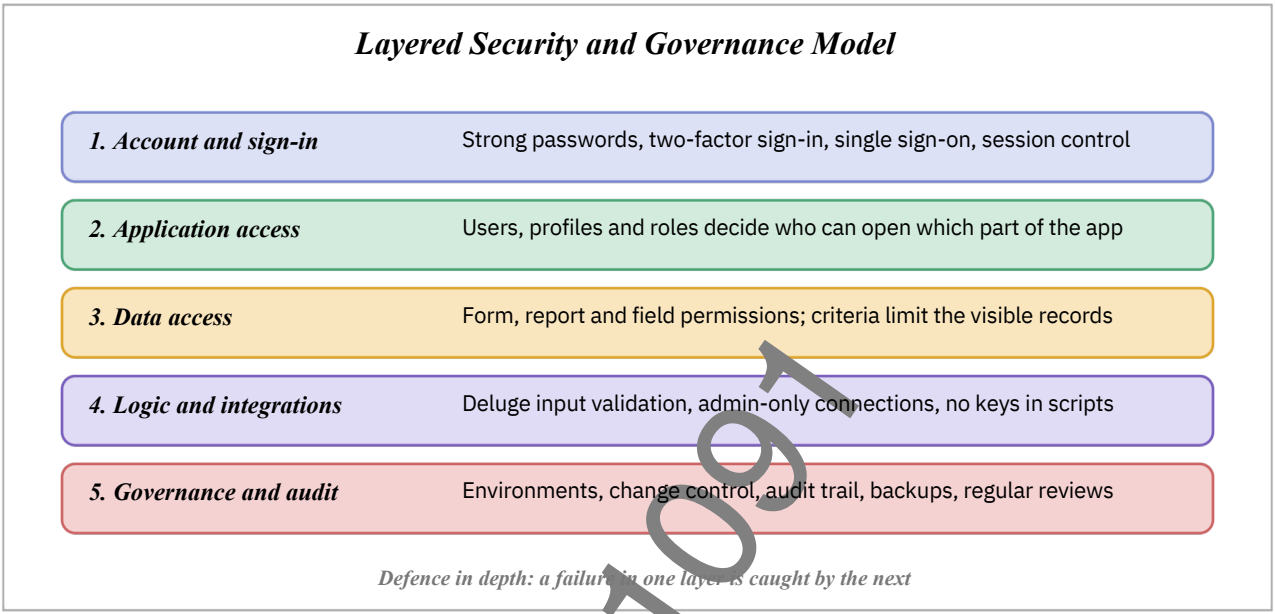
Step 7: Prepare the admin checklist — Threats and matching controls were tabulated, and an administration checklist was prepared for regular use (Sections 3.6 and 3.7).

Note: the settings are described as a planned configuration. No screenshots of the settings were captured for this record, so it does not claim that every option was turned on. Feature names and availability depend on the Zoho Creator plan and version and should be confirmed in the current documentation.

241401091

3. Output

3.1 Layered security and governance model



Security is arranged in five layers: account sign-in, application access, data access, logic and integrations, and governance with audit. A failure in one layer is caught by the next, which is the idea of defence in depth.

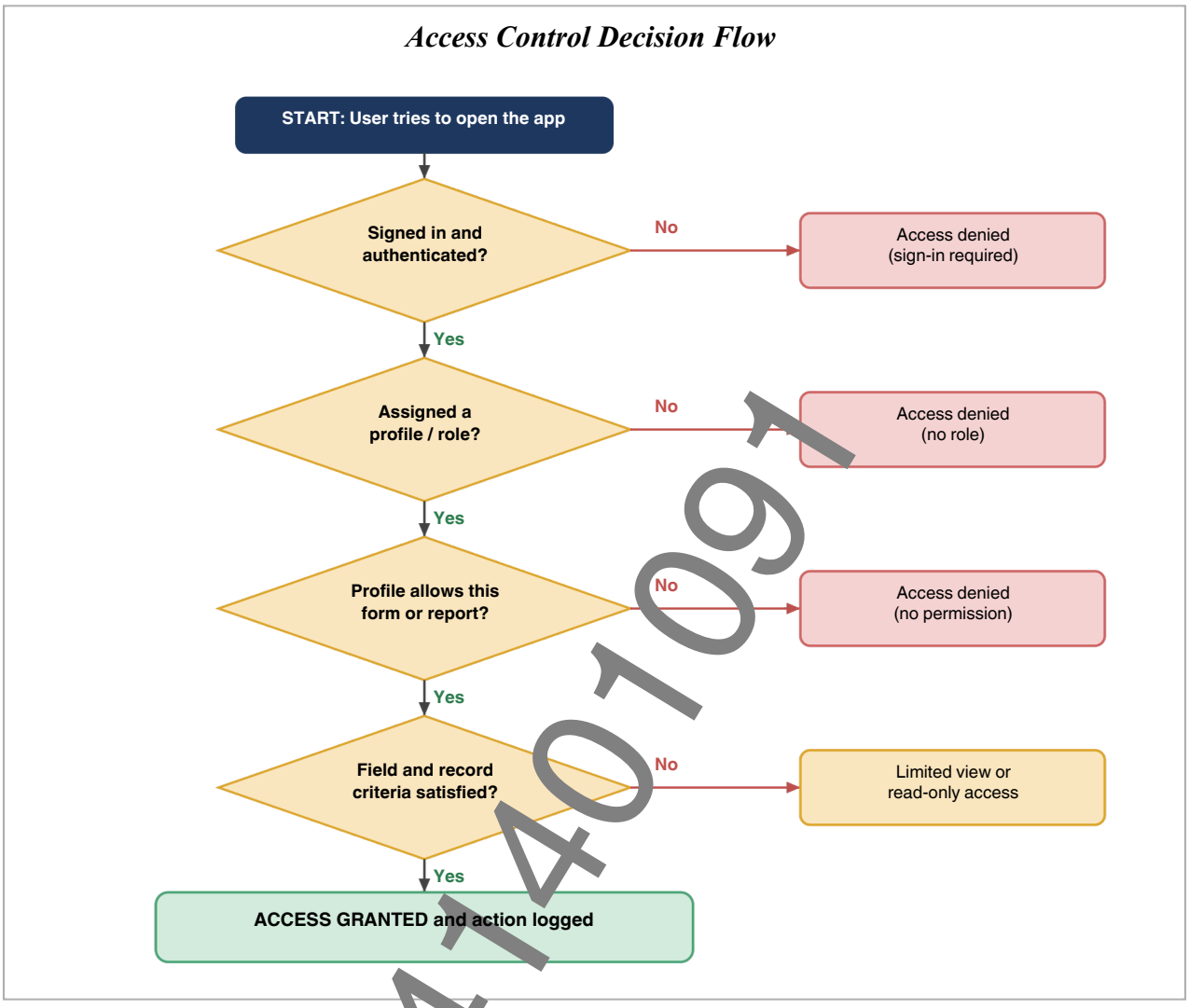
3.2 Proposed permission matrix

Each user type receives only the access needed for the job (least privilege). The matrix is a proposed design for the service request system.

Form / report	*Administrator*	*Front Office Executive*	*Technician*	*Vehicle Owner*
Service_Request_Form (requests) Service_Request_Report	View, edit, delete	Create, view, edit	View assigned requests View assigned jobs	Create and view own request View own request
	Full access	View all, assign technician and bay		
Service types and bay schedule settings	Full access	View, schedule	View	No access
Contact number, pickup address	View, edit	View, edit	Limited or hidden	Own entry only
Reports and exports	All reports, export	Daily schedule, export	Assigned job list only	No
Users, connections, environments	Manage	No access	No access	access No access

24140109

3.3 Access control decision flow



When a user tries to open the application, the system checks sign-in, then the assigned profile or role, then permission on the form or report, and finally field and record criteria. Failing any check denies or limits access, and granted actions are logged.

24140109 1

3.4 Secure scripting and connection practices (illustrative)

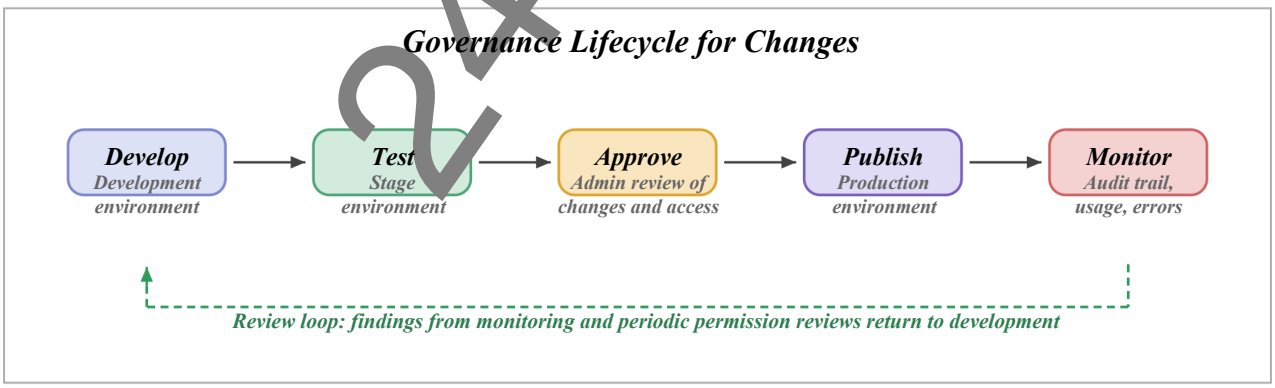
```
// On validate of the Service_Request_Form
if(input.Authorize_Estimate_And_Repair != true)
{

      alert "Please authorize the service center to prepare an estimate.";
      cancel submit;
  }
  if(input.Odometer_Reading <= 0)
  {
      alert "Odometer reading must be a positive value.";
      cancel submit;
  }
  if(input.Preferred_Service_Date < zoho.currentdate)
  {
      alert "Preferred Service Date cannot be in the past.";
      cancel submit;
  }

  // Connection: use the stored link name, never a key written in the script
  response = invokeurl
  [
      url :sms_gateway_url
      type :POST
      parameters :payload.toString()
      connection :"service_sms_connection"
  ];
```

Input is validated on the server side of the form so wrong or missing data is rejected. Credentials stay in the connection, which is set to administrators only, and the gateway URL should be stored in a setting instead of being written inside the scripts. The code is illustrative; the connection and gateway named in it are examples and were not set up in this application.

3.5 Governance lifecycle for changes



Changes move from the development environment to the stage environment for testing, then to an administrator review, and only then to the production environment. Monitoring through the audit trail and periodic permission reviews feed improvements back into development.

24140109 1

3.6 Threats and matching controls

Threat	*Example in this application*	*Control*
Unauthorised access	A stranger or former staff member opens owner and vehicle data. A technician can delete or export all service requests.	Two-factor sign-in, remove users promptly, profile-based access. Least privilege, separate permissions for delete and export.
Excess privilege	The service request form or report is shared publicly by mistake.	Review sharing settings; limit public links to the service request form only and never share the report.
Data leakage	Missing validation, or keys written inside Deluge code.	Validation on submit, connections instead of keys, code review. Development, stage and production environments with approval.
Insecure scripts	A live fix breaks the form or permissions.	Audit trail review and periodic log checks.
Uncontrolled change	Nobody can tell who changed a request or assigned a technician.	
No traceability		

3.7 Administration checklist

Area	*Administration practice*	*How often*
Users	Add users with the correct profile; remove leavers the same day.	On every change
Permissions	Review profiles and exports against the permission matrix.	Every quarter
Sign-in	Confirm two-factor sign-in or single sign-on is enforced.	Every quarter
Connections	Check that connections are administrator-only and used only by needed apps.	Every quarter
Changes	Publish only after testing in the stage environment.	Every release
Audit	Look through the audit trail and usage metrics for unusual activity.	Monthly
Backup and recovery	Keep a recent backup and test that data can be restored.	As planned

24140109 1

4. Final Result

A layered security and governance plan was prepared for the Vehicle Service & Repair Request Management application, covering sign-in protection, role-based access with a least-privilege permission matrix, an access-control decision flow, secure scripting and connection practices, controlled changes through environments, and regular auditing. Threats such as unauthorised access, excess privilege, data leakage, insecure scripts, uncontrolled change and lack of traceability were matched with controls, and an administration checklist was drawn up for regular use.

The exercise met its objective of designing security and governance for the application. The settings were not captured as screenshots, so the record presents them as a planned configuration to be confirmed in the live application.